DHBW
Duale Hochschule
Baden-Württemberg

Data Secruity - GridVault

Dokumentation

Studiengang Informatik Cybersecurity

Duale Hochschule Baden-Württemberg Stuttgart

Felix Hennerich

Eingereicht am:	12.11.2026
Matrikelnummer, Kurs:	2594549, TINF24F
Dozent an DHBW:	Florian Schüssler

Inhalt

1 Architektur-Abgleich und Entscheidungen (B1) 1
1.1 Abgleichstabelle 1

2 Schutzbedarf und Risiken der Datenaggregation (B2) 3

3 Cloud-Betrieb und Zusammenarbeit mit dem Provider (B3) 4

4 Testprotokoll (B4) 5

5 Zwecke, Rechtsgrundlagen und Transparenz (B5) 6

6 Löschung, Berechtigungen und Datenpanne (B6) 7

7 EU-Hosting und US-Anbieter (B7) 8

A Literatur 9

B Glossar 10

C Anhang 11
C.1 KI-Deklaration 11
C.2 Archtekturentwurf 12
C.2.1 Data Security 12
C.2.2 Data Protection 16

1

Architektur-Abgleich und Entscheidungen (B1)

1.1 Abgleichstabelle

Merkmal	Klausur	Umsetzung	Gleich / Anders	Grund
Sprache und Libs	Python FastAPI mit PostgreSQL	Python FastAPI mit SQLite / argon2-cffi und cryptography / uv als Paketmanager	PostgreSQL -> SQLlite	Entwicklungsumgebung mit einfacher Möglichkeit der Migration
Ablage des Hauptschlüssels	Separater Schlüsseldienst in extra Service	256-Bit-Hauptschlüssel je Stadtwerk als Hex-Datei in keys/.key / Schlüsseldienst keys.py (eigentlich auch seperates skript)	Kein extra service	Extra service würde im produktivbetrieb mit der keys.py aufgebaut werden.
Kontextbindung				
Mandantentrennung	-	Gateway prüft Stadtwerk Übereinstimmung vor jedem Objektzugriff & Mandant Hauptschlüssel benötigt	-	-

Merkmal	Klausur	Umsetzung	Gleich / Anders	Grund
Störungsfreigabe	Vier-Augen-Prinzip / Freigab läuft ab / Loggin	Vier-Augen-Prinzip / Antragsteller kann nicht selber genehmigen / Freigabe 30 Minuten gültig	-	-
Audit-Schutz		Append Only bei Logs / Externer Anchor in separatem verzeichnis als WORM-Dummy	-	-
Löschlauf	-	Frist ab Messzeitstempel / Abgelaufene Daten werden gelöscht. Dry-Run zählt vorab / Einzelne Löschanfragen via DataKey löschung -> Daten unlesbar	-	-
Berechtigungsprüfung	-	Zentrale Prüfkette im gateway.py	-	-

2

Schutzbedarf und Risiken der Datenaggregation (B2)

3

Cloud-Betrieb und Zusammenarbeit mit dem Provider (B3)

4

Testprotokoll (B4)

5

Zwecke, Rechtsgrundlagen und Transparenz (B5)

6

Löschung, Berechtigungen und Datenpanne (B6)

7

EU-Hosting und US-Anbieter (B7)

A Literatur

B Glossar

C Anhang

C.1 KI-Deklaration

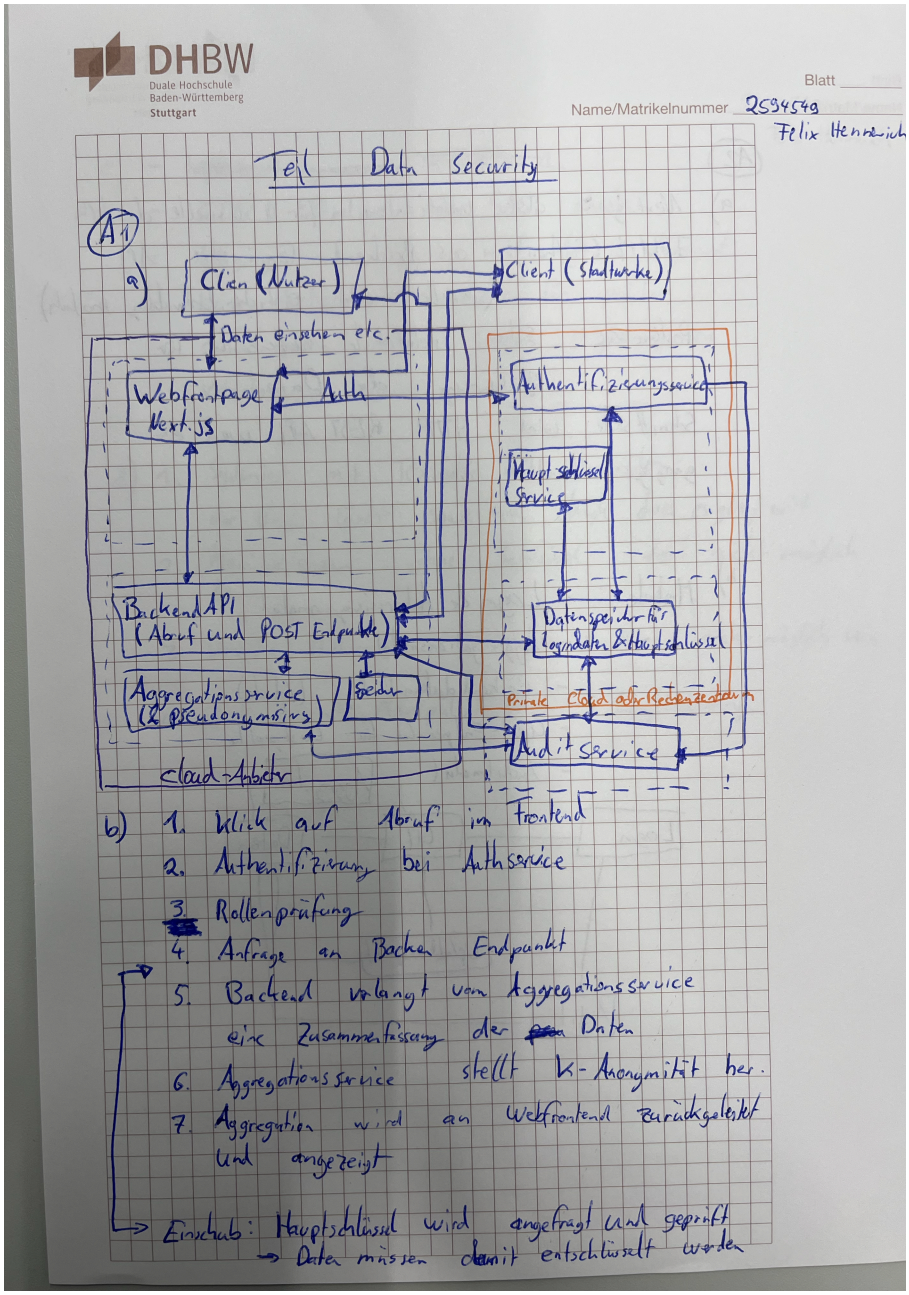
Für die Bearbeitung der Aufgabe wurden folgende KI-Werkzeuge eingesetzt:

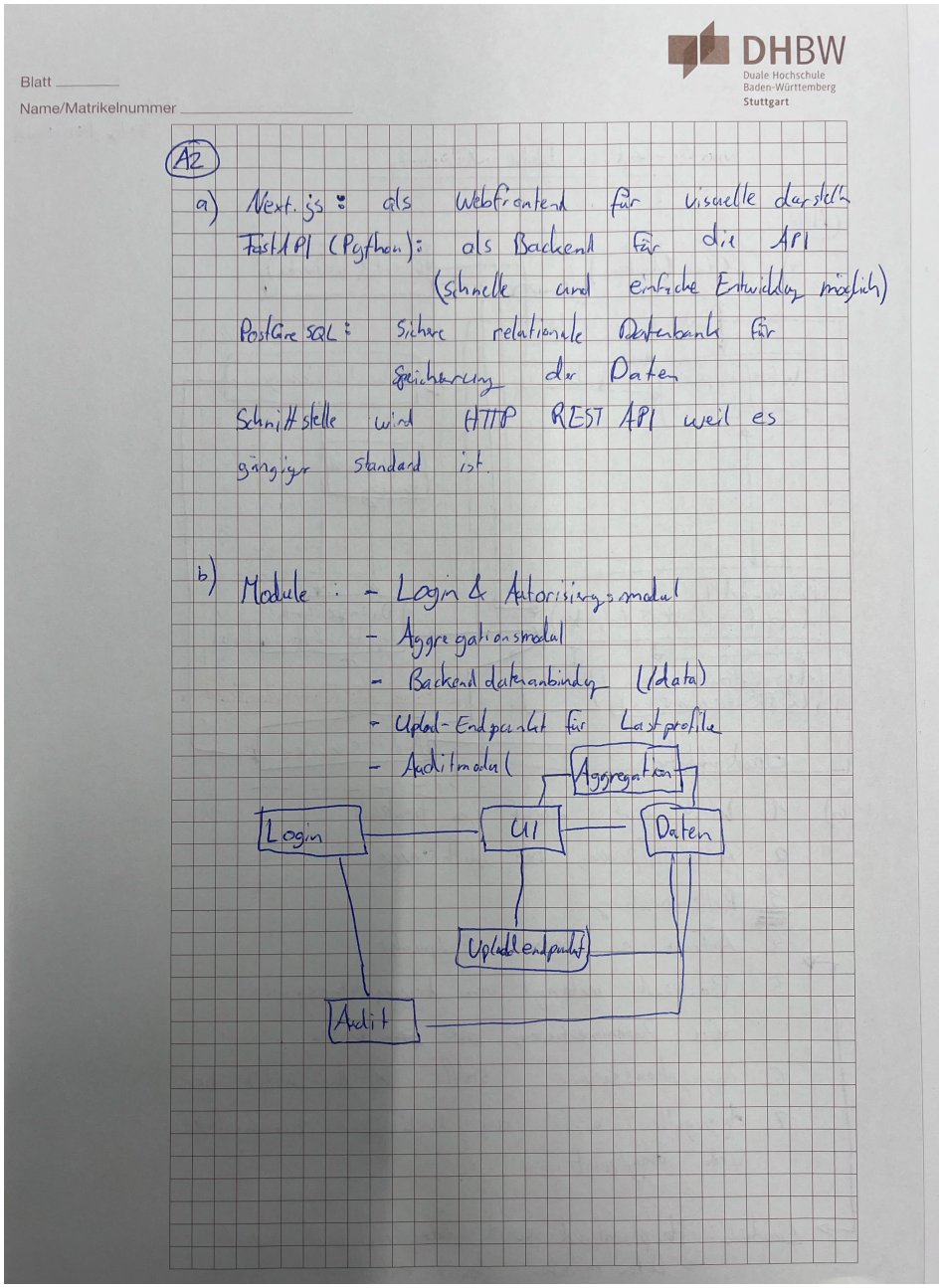
1. Mistral Vibe (GLM 5.3): Code-Generierung
Dieses Modell wurde zur Generierung und Strukturierung des Codes verwendet. Dabei wurden Vorschläge des Modells für die Implementierung einzelner Programmteile übernommen, geprüft und an die Aufgabenstellung angepasst.

2. Mistral Large 4: Grammatikalische Korrektur und Fehlererkennung
Dieses Modell wurde abschließend zur sprachlichen Überarbeitung des Typst Dokuments eingesetzt. Es diente der Korrektur von Grammatik, Rechtschreibung und Zeichensetzung sowie der Erkennung inhaltlicher Unstimmigkeiten und unklarer Formulierungen im Text.

C.2 Archtekturentwurf

C.2.1 Data Security





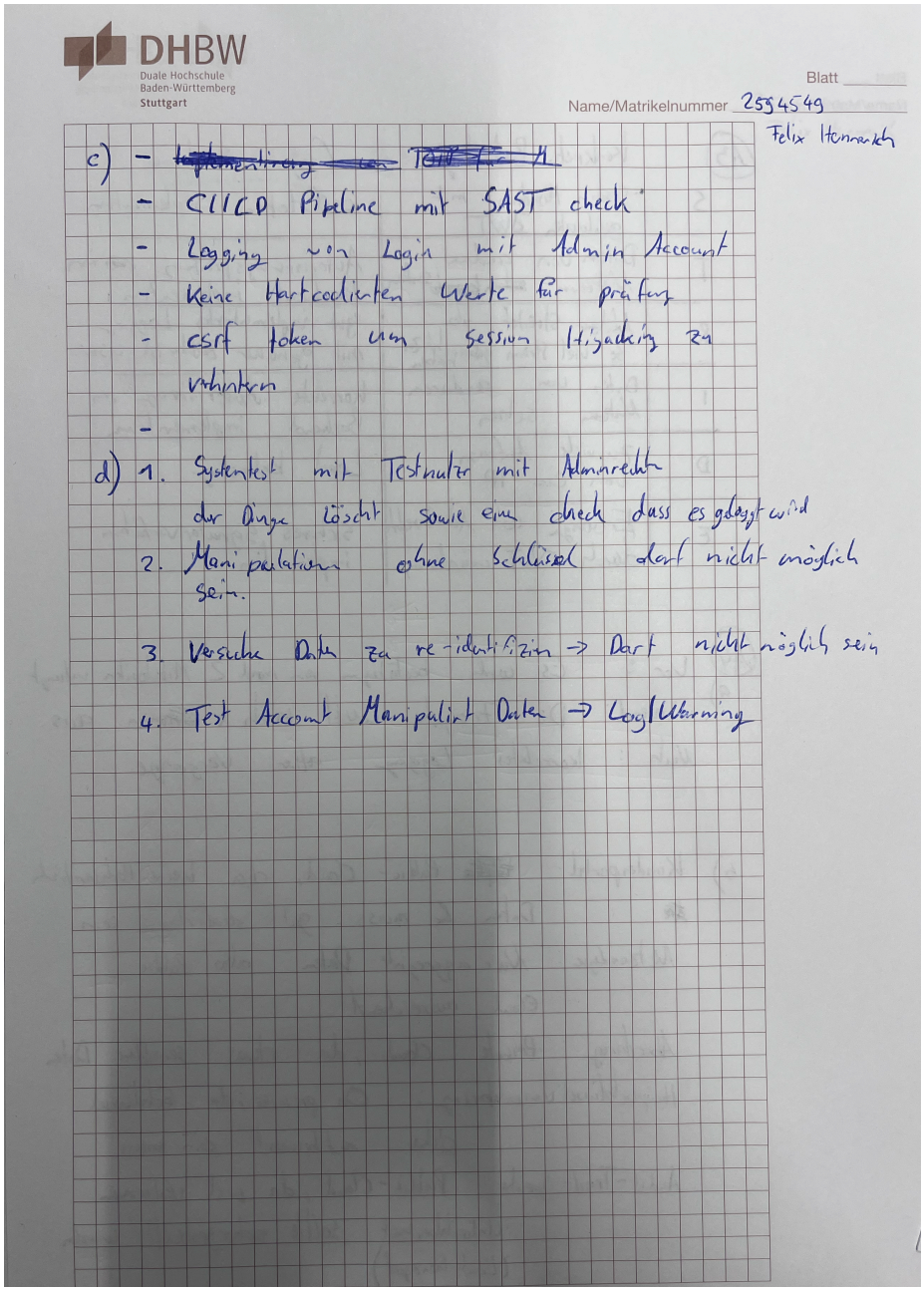
Blatt _____
Name/Matrikelnummer _____

DHBW
Duale Hochschule
Baden-Württemberg
Stuttgart

A2

a) Next.js: als Webfrontend für visuelle darstellung
FastAPI (Python): als Backend für die API
(schnelle und einfache Entwicklung möglich)
PostgreSQL: Sichere relationale Datenbank für
Speicherung der Daten
Schnittstelle wird HTTP REST API weil es
gängiger Standard ist.

b) Module:
- Login & Autorisierungsmodul
- Aggregationsmodul
- Backend datenanbindung (/data)
- Upload-Endpunkt für Lastprofile
- Auditmodul



DHBW
Duale Hochschule
Baden-Württemberg
Stuttgart

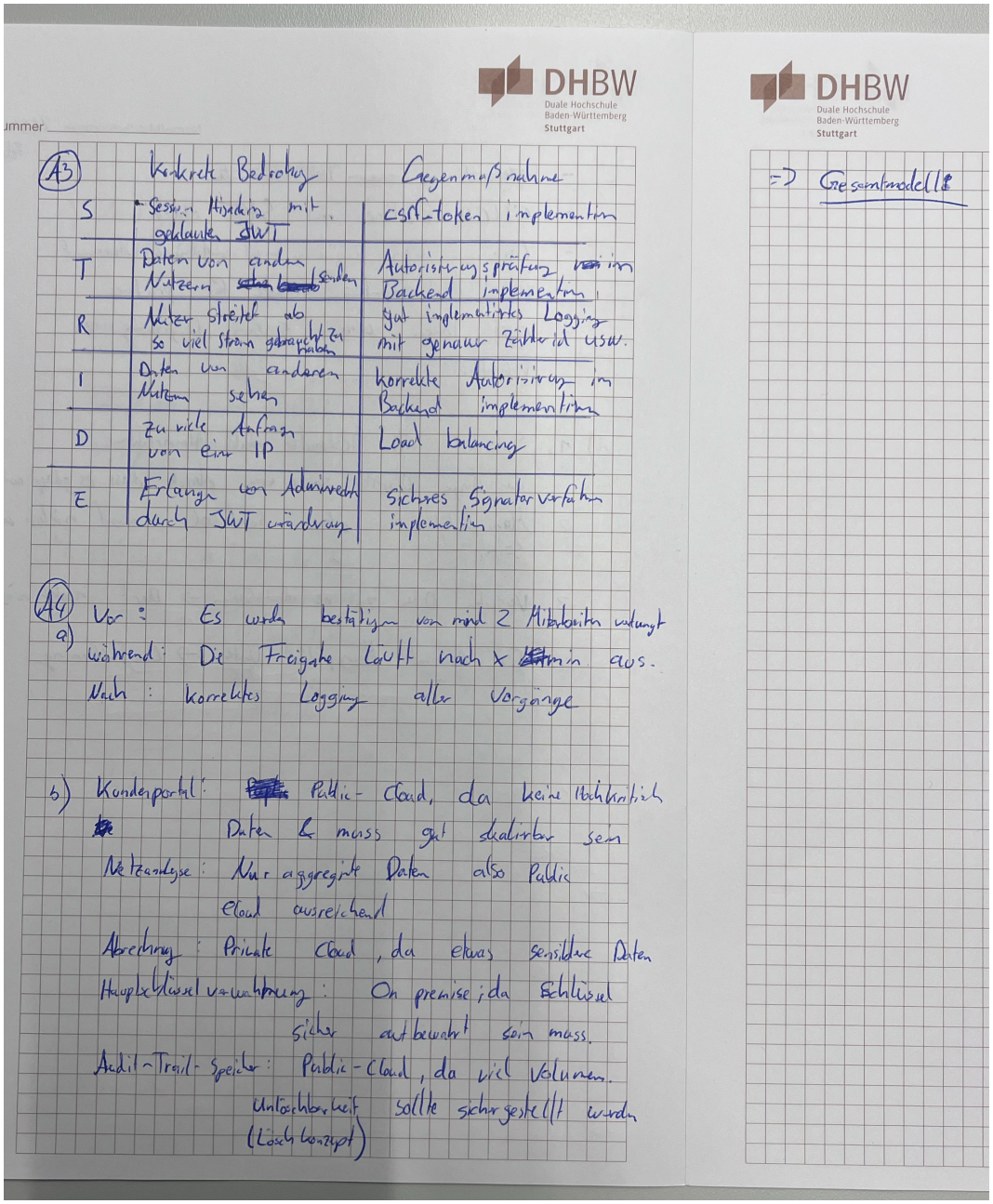
Blatt

Name/Matrikelnummer 2554549

Felix Hennrich

c) - ~~Implementierung Test für M~~
- CI/CD Pipeline mit SAST check
- Logging von Login mit Admin Account
- Keine Hartcodierten Werte für prüfung
- csrf token um session Hijacking zu verhindern
-

d) 1. Systemtest mit Testnutzer mit Adminrechte der Dinge löscht sowie eine check dass es gelöscht wird
2. Manipulation ohne Schlüssel darf nicht möglich sein.
3. Versuche Daten zu re-identifizieren → Darf nicht möglich sein
4. Test Account Manipulirt Daten → Log/Warning



DHBW
Duale Hochschule
Baden-Württemberg
Stuttgart

ummer

A3

	Konkrete Bedrohung	Gegenmaßnahme
S	Session Hijacking mit gehackter JWT	csrf-token implementiern
T	Daten von anderen Nutzern sehen	Autorisierungsprüfung im Backend implementiern
R	Nutzer stritet ab so viel Strom gebraucht zu haben	gut implementiertes Logging mit genauer Zeit- id usw.
I	Daten von anderen Nutzern sehen	korrekte Autorisierung im Backend implementiern
D	Zu viele Anfragen von einer IP	Load balancing
E	Erlangen von Adminrecht durch JWT veränderung	sicheres Signaturverfahren implementiern

A4

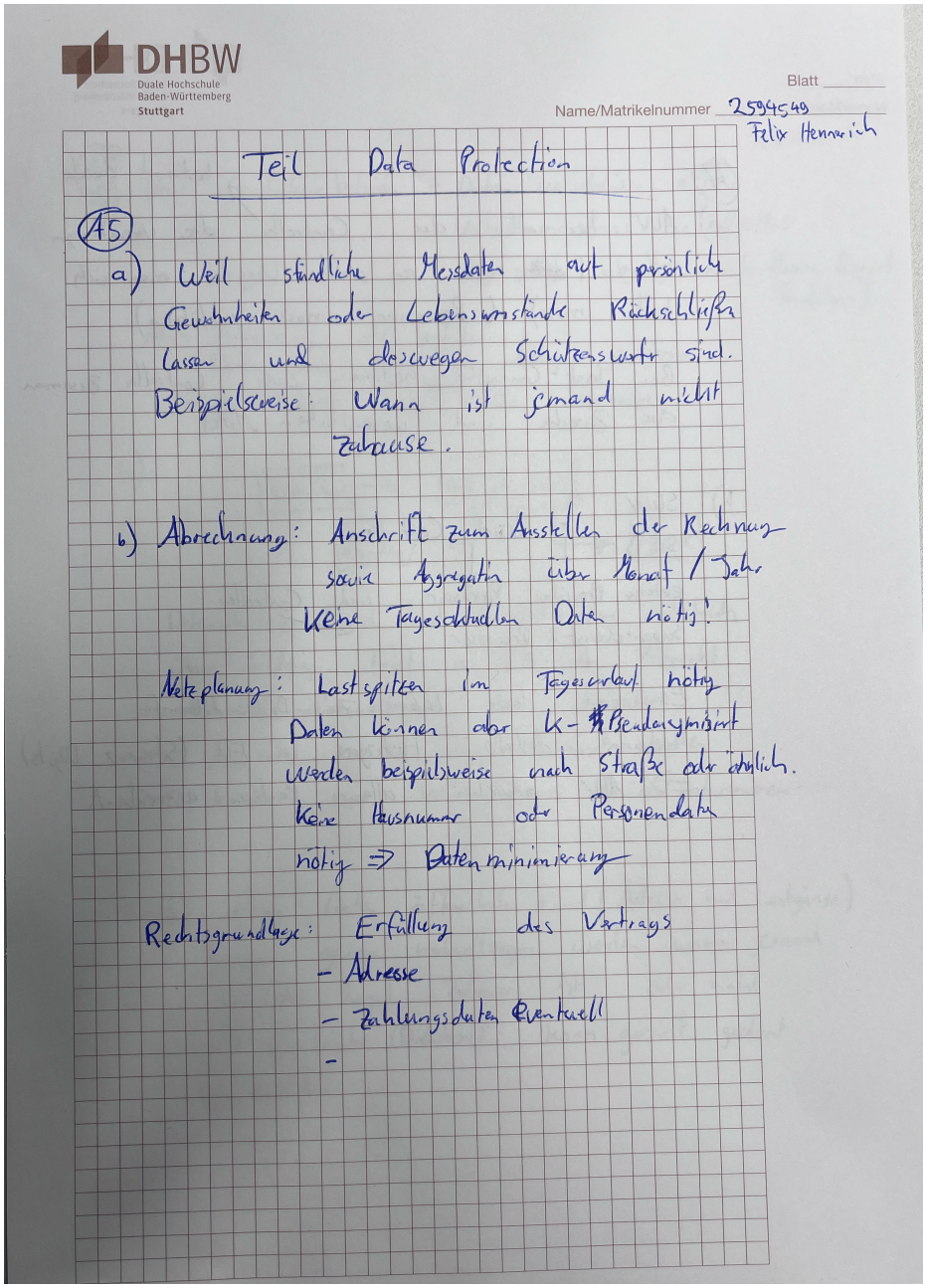
a) Vor: Es werden bestätigen von mind 2 Mitarbeitern validiert
Während: Die Freigabe läuft nach x min aus.
Nach: korrektes Logging aller Vorgänge

b) Kundenportal: Public-Cloud, da keine Hochkritischen Daten & muss gut skalierbar sein
Netzanalyse: Nur aggregierte Daten also Public Cloud ausreichend
Abrechnung: Private Cloud, da etwas sensitivere Daten
Hauptschlüsselverwaltung: On premise; da Schlüssel sicher aufbewahrt sein muss.
Audit-Trail-Speicher: Public-Cloud, da viel Volumen. Unlöschbarkeit sollte sichergestellt werden (Löschkonzept)

DHBW
Duale Hochschule
Baden-Württemberg
Stuttgart

=> Gesamtmodell

C.2.2 Data Protection



DHBW
Duale Hochschule
Baden-Württemberg
Stuttgart

Blatt ____

Name/Matrikelnummer 2594549
Felix Hennerich

Teil Data Protection

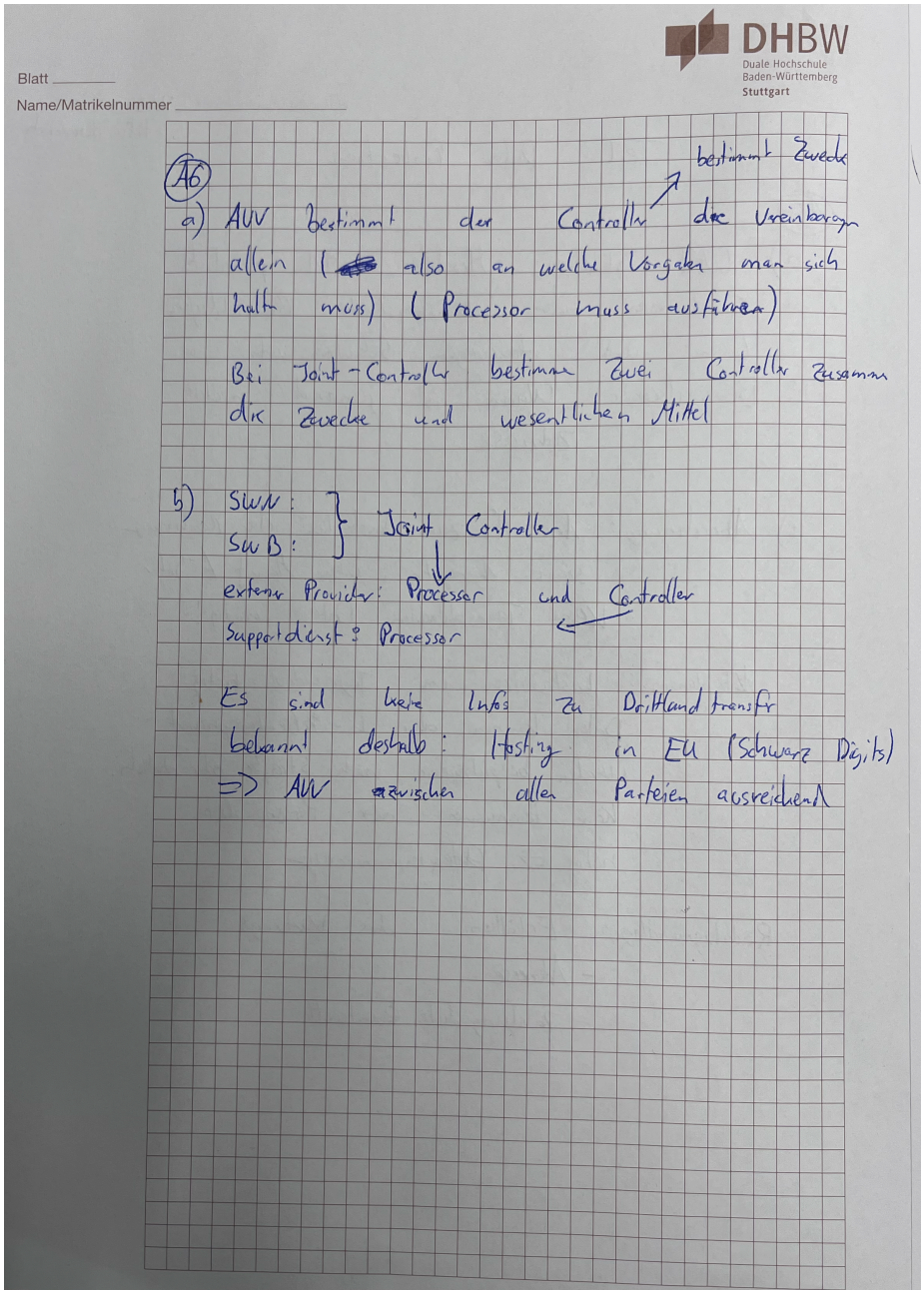
A5

a) Weil stündliche Messdaten auf persönliche Gewohnheiten oder Lebensumstände Rückschlüsse lassen und deswegen Schutzwürdig sind. Beispielsweise: Wann ist jemand nicht Zuhause.

b) Abrechnung: Anschrift zum Ausstellen der Rechnung sowie Aggregation über Monat / Jahr
Keine Tagesaktuellen Daten nötig!

Netzplanung: Lastspitzen im Tagesverlauf nötig
Daten können aber k-#Pseudonymisiert werden beispielsweise nach Straße oder ähnlich.
Keine Hausnummer oder Personendaten nötig ⇒ Datenminimierung

Rechtsgrundlage: Erfüllung des Vertrags
- Adresse
- Zahlungsdaten (Kontakt)
-



Blatt _____
Name/Matrikelnummer _____

DHBW
Duale Hochschule
Baden-Württemberg
Stuttgart

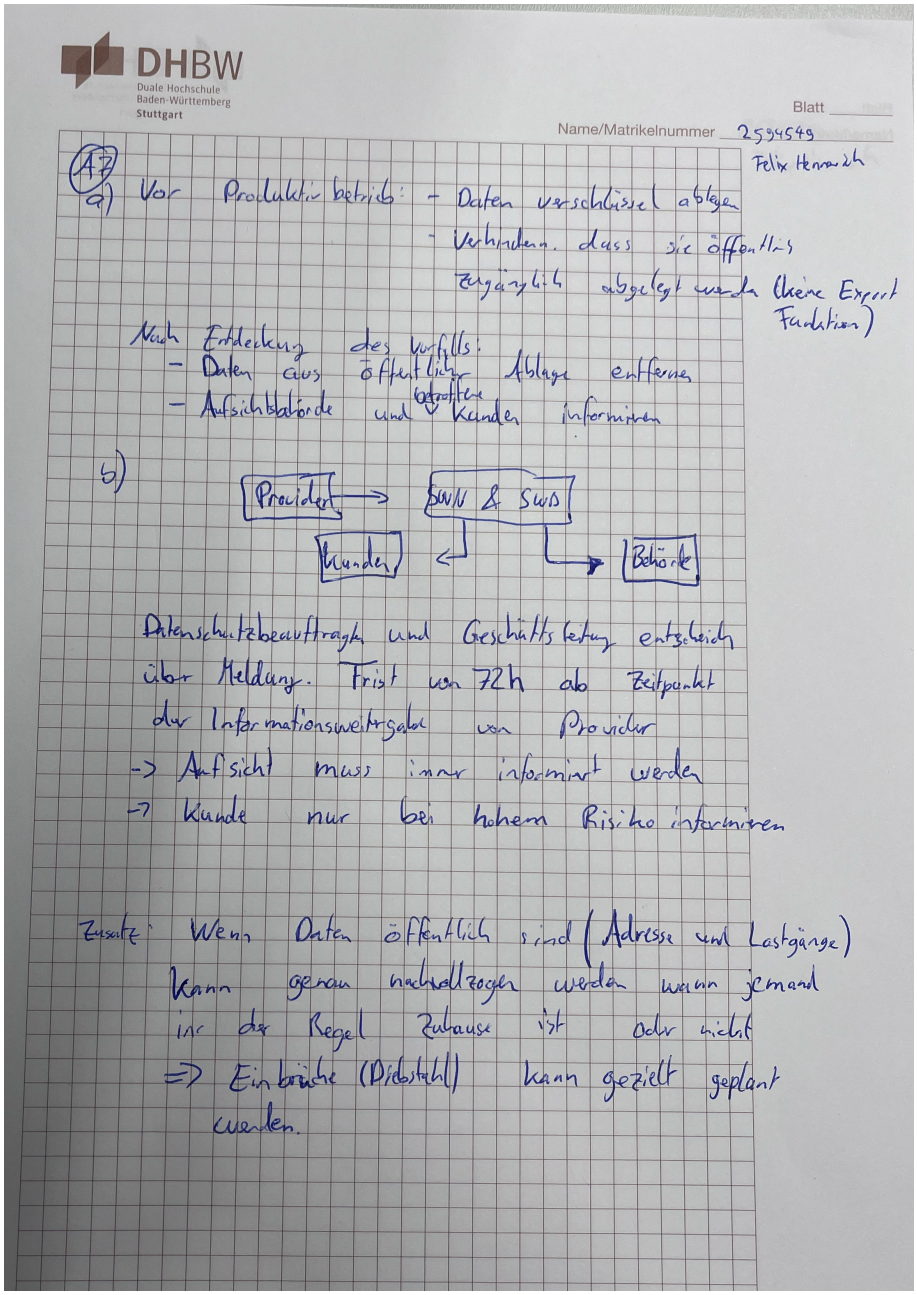
A6

a) AVV bestimmt der Controller (bestimmt Zwecke) die Vereinbarung allein (also an welche Vorgaben man sich halten muss) (Processor muss ausführen)

Bei Joint-Controller bestimmen zwei Controller zusammen die Zwecke und wesentlichen Mittel

b) SwV: } Joint Controller
SwB: }
externer Provider: Processor und Controller
Supportdienst: Processor

Es sind keine Infos zu Drittland transfer bekannt deshalb: Hosting in EU (Schwarz Digits)
=> AVV zwischen allen Parteien ausreichend



DHBW
Duale Hochschule
Baden-Württemberg
Stuttgart

Blatt

Name/Matrikelnummer 2594549

Felix Henrich

A7

a) Vor Produktivbetrieb: - Daten verschlüsselt ablegen
- Verhindern, dass sie öffentlich zugänglich abgelegt werden (keine Export Funktion)

Nach Entdeckung des Vorfalls:
- Daten aus öffentlicher Ablage entfernen
- Aufsichtsbehörde und betroffene Kunden informieren

b)

Datenschutzbeauftragte und Geschäftsleitung entscheidet über Meldung. Frist von 72h ab Zeitpunkt der Informationsweitergabe von Provider
-> Aufsicht muss immer informiert werden
-> Kunde nur bei hohem Risiko informieren

Zusatz: Wenn Daten öffentlich sind (Adresse und Lastgänge) kann genau nachvollzogen werden wann jemand in der Regel Zuhause ist oder nicht
=> Einbrüche (Diebstahl) kann gezielt geplant werden.